INFORME DE ARQUITECTURA

Ecosistema EUDI Wallet de Avance

Arquitectura tal como está construida y operando: wallet, emisores, verificadores, confianza, firma y auditoría

Versión 1.0 · **Fecha de corte** 12 de noviembre de 2026
Entorno civica-desarrollo.avance.org.co (banco de pruebas)
Base código y servicios del repositorio `Avance-Centralizado` y 91 contenedores en ejecución
Marco de referencia ARF 3.0.0 · OpenID4VCI · OpenID4VP · SD-JWT VC · ETSI TS 119 612

Este informe describe lo que **existe y se ha probado** en el ecosistema. Lo que es diseño, simulación o brecha se marca como tal.

Contenido

1. Resumen ejecutivo
2. Alcance, método y notación
3. Vista de contexto
4. Vista de despliegue y red
5. Catálogo de componentes
6. La wallet (New Wallet)
7. Emisión de credenciales
8. Presentación y verificadores
9. Modelo de confianza
10. Revocación y recuperación
11. Firma electrónica (Andes SCD)
12. Auditoría y operación
13. Seguridad y privacidad
14. Decisiones de arquitectura
15. Estado, brechas y riesgos
16. Hoja de ruta
17. Anexos: rutas, credenciales, glosario, fuentes

1. Resumen ejecutivo

El proyecto construyó un ecosistema completo de identidad digital sobre el modelo europeo EUDI: una **wallet Android** donde la persona guarda sus credenciales, **emisores** que las entregan, **verificadores** que las piden y comprueban, y una **capa de confianza** (listas firmadas, validador y listas de estado) que permite que todos se fíen entre sí sin una base de datos central. Se suman **onboarding** para obtener el PID, un **prestador de firma remota** simulado (Andes SCD), un **centro de auditoría** de las wallets y un **panel de control** para operarlo todo.

> **Lo construido, en cifras** (corte 12-nov-2026): 91 contenedores en ejecución · 4 emisores sobre la pila oficial EUDI (Registraduría, Tránsito, UIS, Notaría) · 6 portales que además emiten credenciales propias (banco, EPS, gimnasio, aerolínea, cancillería, notaría simple) · 14 verifiers con su portal · 5 listas de confianza más la LOTL · 1 wallet Android · 1 prestador de firma remota (CSC v2) · 1 centro de auditoría con base PostgreSQL.

Decisiones que definen la arquitectura

- **Un único borde.** Todo el tráfico entra por un nginx (`nw-nginx`) y se reparte por prefijos de ruta dentro de una red Docker compartida. Ningún servicio publica puertos.
- **Un verifier por portal.** Cada aplicación (banco, beca, pensiones…) tiene su propia instancia del verifier oficial, con su certificado de acceso, en lugar de un verificador genérico compartido.
- **La confianza se resuelve por cadena de certificados** contra anclas publicadas en listas ETSI, no por la URL del emisor.
- **Las claves del titular nunca salen del teléfono.** La firma remota (Andes SCD) guarda las claves de firma cifradas y exige el PID en cada autorización.
- **Sin DID ni registro verificable obligatorio:** el camino es OpenID4VCI/OpenID4VP con SD-JWT VC y mdoc, como en el ARF.

Qué es de prueba

Todas las entidades (Registraduría, notarías, banco, EPS…) son **simuladas** y los datos son de ejemplo. Andes SCD es un simulador que no tiene respaldo de ONAC. La comparación facial del onboarding mide parecido pero no hace prueba de vida. El ecosistema no está certificado ni reconocido por ninguna autoridad. La sección 15 detalla las brechas.

2. Alcance, método y notación

2.1 Propósito

Dar al equipo de arquitectura, desarrollo, seguridad y operación una descripción **fiel al código y a lo desplegado**: qué componentes hay, cómo se conectan, qué protocolos usan y dónde están sus límites. Complementa al documento de arquitectura objetivo (*Arquitectura de Identidad Digital Colombiana*): aquel define el diseño propuesto; este documenta lo realizado y lo que difiere.

2.2 Método

La información sale de tres fuentes cruzadas: (1) el repositorio (código, compose, nginx, scripts), (2) los servicios en ejecución (contenedores, endpoints, listas publicadas) y (3) las pruebas hechas con la wallet instalada en un teléfono. Cuando una afirmación solo está en documentos y no se comprobó, se indica.

2.3 Notación

Marca	Significado
C	Componente de referencia EUDI (o de un tercero) instalado y configurado, sin cambios de fondo.
I	Integración o parche acotado sobre un componente de referencia.
D	Desarrollo propio del proyecto.
S	Simulado: imita a una entidad o servicio real para el banco de pruebas.
EXT	Sistema o autoridad externa al proyecto.

Las capas de los diagramas agrupan responsabilidades; no son una cadena por la que pase cada mensaje.

3. Vista de contexto

El ecosistema sigue el triángulo del ARF: el **emisor** entrega una credencial a la **wallet** del titular y el **verificador** la pide a esa misma wallet; la **confianza** es lo que permite al verificador y a la wallet aceptar a un emisor o a un verificador que no conocían de antemano.

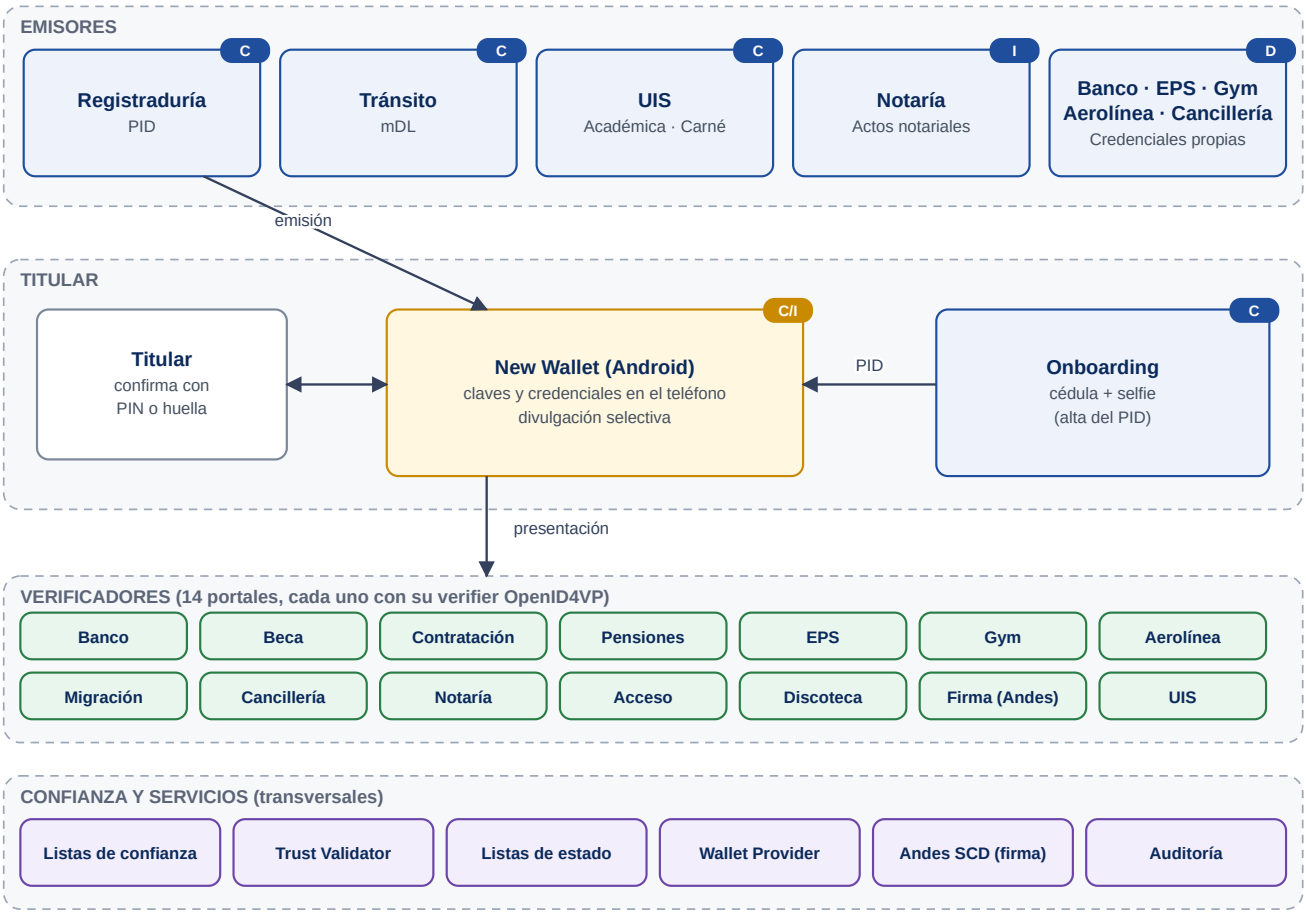


Figura 1. Contexto del ecosistema: quién emite, quién guarda, quién verifica y qué lo hace confiable.

Cuatro rasgos distinguen este ecosistema de una instalación mínima de referencia:

1. **Muchos emisores y muchos verificadores reales** (de ejemplo) cubriendo casos de uso completos: abrir una cuenta, afiliarse a una EPS, comprar un pasaje, pasar migración, firmar un contrato.
2. **Credenciales encadenadas.** Una credencial se obtiene con otra: casi todo se pide identificándose con el PID, y la fe de vida de una notaría sirve para la prueba de supervivencia de un fondo de pensiones.
3. **Operación centralizada pero no intrusiva:** un centro de auditoría ve lo que hace cada wallet, y un panel arranca y detiene los stacks, sin participar en ningún flujo de credenciales.
4. **Firma electrónica** integrada en la wallet mediante un prestador remoto que identifica al firmante con su PID.

4. Vista de despliegue y red

Todo corre en contenedores Docker sobre un host. El tráfico llega por el proxy público (que termina el certificado comodín del dominio) y entra a un único nginx interno que enruta por prefijo hacia los servicios de la red `avance-eudi`.

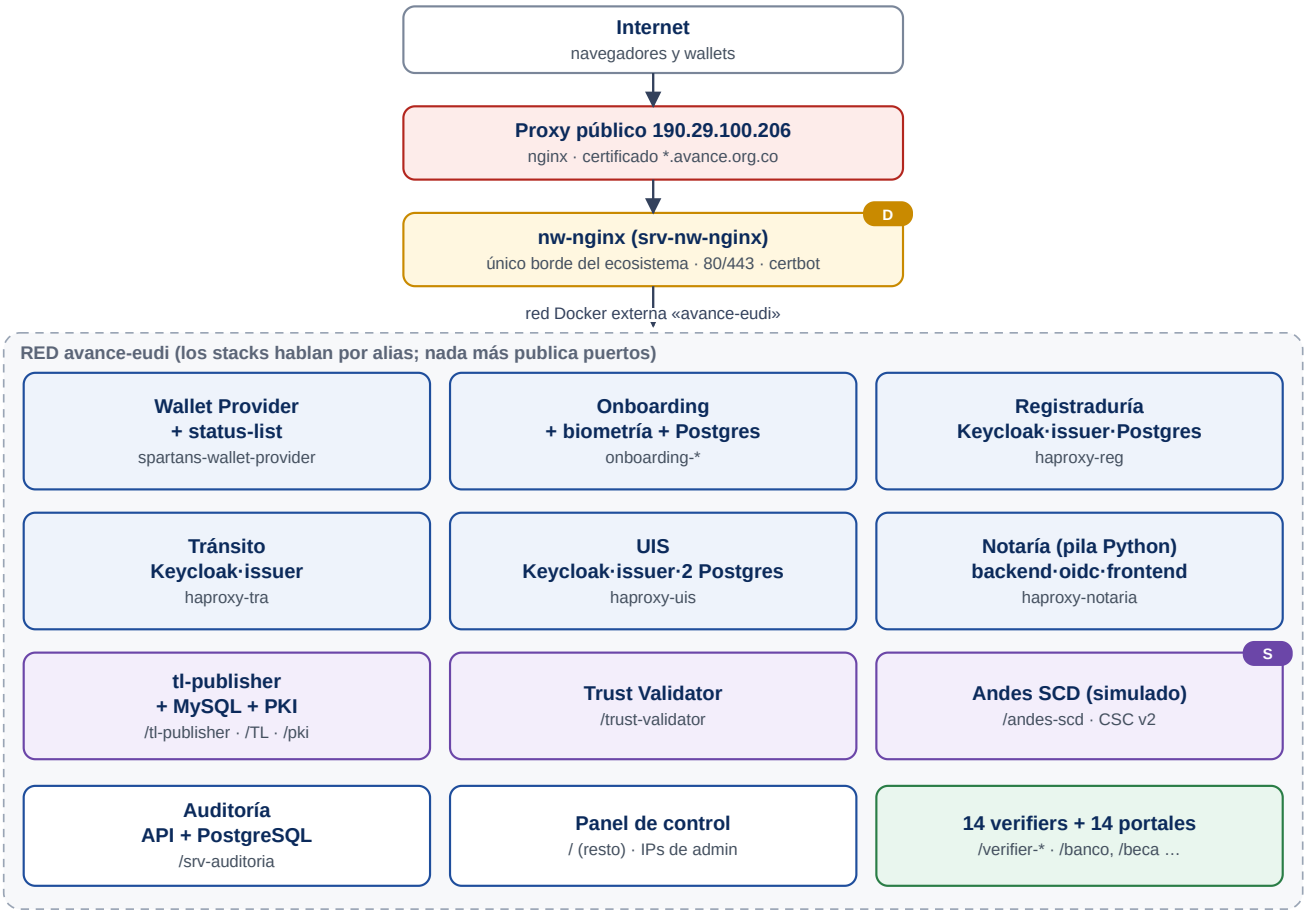


Figura 2. Despliegue: un borde, una red compartida y stacks independientes.

4.1 Cómo se organiza

- **Un compose por proyecto.** Cada stack vive en su carpeta y se levanta solo; el compose raíz (`up.sh`) los reúne. Cada stack declara su red con nombre propio para no fusionarse al incluirlos.
- **Bases de datos privadas.** PostgreSQL y MySQL no se publican ni se enrutan por HTTP.
- **haproxy interno por emisor.** Cada emisor tiene un haproxy que **reescribe** las rutas *well-known* y reparte entre su frontend, backend, servidor de autorización y Keycloak; el borde enruta, el haproxy reescribe.
- **Regla de oro de rutas:** la URL que el emisor declara como pública es exactamente la que enruta el nginx. En el `map` del nginx gana la primera expresión regular que coincide, por lo que las rutas específicas van antes que las genéricas.

4.2 Restricciones del borde público

El proxy público reescribe el `Path` de todas las cookies a `/`. Consecuencias de diseño: dos Keycloak en el mismo dominio comparten cookies de sesión (por eso el panel ofrece «Activar consola» explícita), y cada portal usa un **nombre de cookie propio** (`pensiones_sesion`, `contratacion_sesion`…) para no pisarse. Los certificados comodín no cubren subdominios de segundo nivel, así que los servicios se separan por **prefijo de ruta**, no por subdominio.

4.3 Aislamiento hacia otros ecosistemas

El dominio del otro ecosistema de pruebas (`civica.avance.org.co`) está bloqueado en `/etc/hosts` y en `extra_hosts` de los servicios. Así las listas y anclas de uno no se mezclan con las del otro: una fuga falla por conexión, no en silencio.

5. Catálogo de componentes

Cada fila indica el rol ARF, el proyecto del repositorio, su ruta pública y su origen (notación de la sección 2).

5.1 Núcleo EUDI

Rol	Proyecto / servicio	Ruta	Origen	Notas
Wallet Unit	`app-new-wallet` (Android, Kotlin/Compose)	—	C I D	Base de referencia EUDI con módulos propios: ofertas del banco, auditoría, apariencia, firma.
Wallet Provider	`eudi-srv-wallet-provider` (+ status-list, Postgres)	/wallet-provider	C I	Atestación de la app (WIA, ABCA). Un solo proveedor valida los dos paquetes Android.
PID Provider	`eudi-srv-issuer-pid-registraduria` (Keycloak, issuer, Postgres, status-list, haproxy)	/pid-registraduria	C I S	Emite el PID en SD-JWT VC y mdoc.
Attestation Provider	`eudi-srv-issuer-pid-transito`	/pid-transito	C I S	Licencia de conducción (mDL) por categorías.
Attestation Provider	`eudi-srv-issuer-pid-uis` (2 Postgres, Keycloak)	/uis-issuer	C I S	Credencial académica y carné estudiantil.
Attestation Provider	`eudi-srv-issuer-pid-notaria` (pila Python: backend, frontend, oidc, status-list)	/notaria-issuer	C I S	Actos notariales. Exige PID para pedir un documento; integración con SIGNO por API de órdenes.
Onboarding	`srv-onboarding` (API, biometría, Postgres)	/onboarding	C I	Foto de cédula + selfie; sin prueba de vida.
Trusted List Provider	`srv-tl-publisher` (MySQL, PKI)	/tl-publisher · /TL · /pki	C I	Publica TL/WP, PID, PUBEAA, QEAA, RPREG y LOTL; emite certificados de acceso.
Trust Validator	`eudi-srv-trust-validator`	/trust-validator	C	Valida cadenas contra el almacén de anclas.
Gateway	`srv-nw-nginx` + certbot	—	D	Único borde; mapa de rutas; control de IPs de administración.

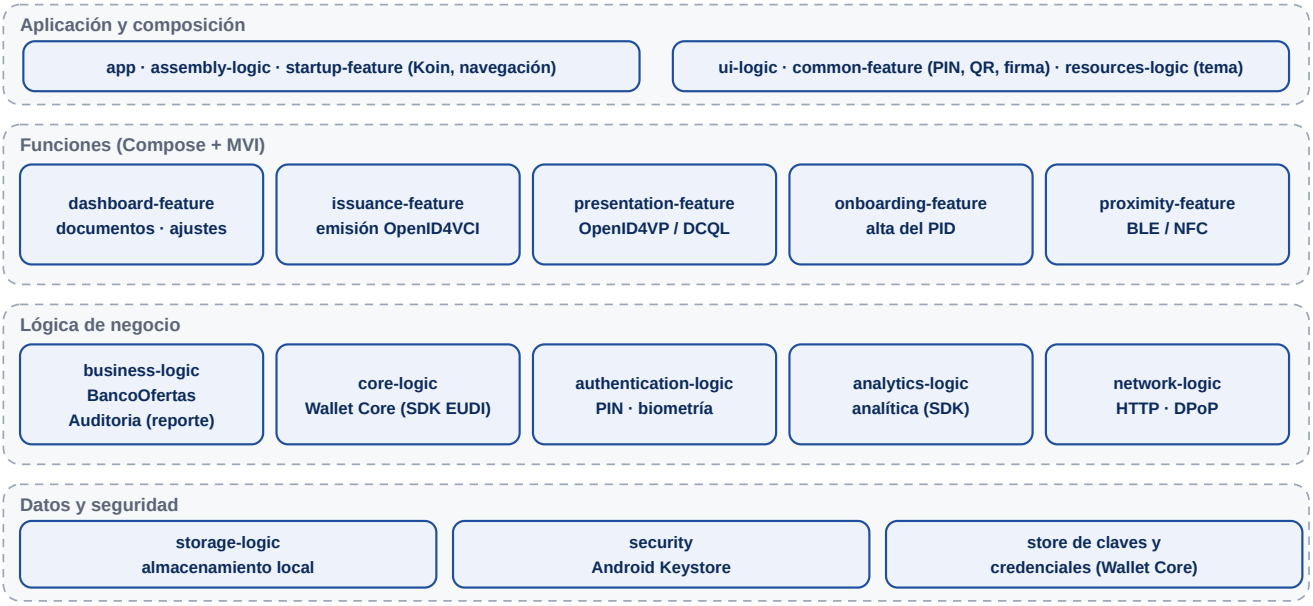
5.2 Servicios propios y transversales

Servicio	Función	Ruta	Origen
Andes SCD (`srv-andes-scd`)	Prestador de firma remota: CSC v2, OAuth2 (PAR/RAR), custodia de claves, sello de tiempo	/andes-scd	D S
Auditoría (`srv-auditoria`)	API de ingesta + PostgreSQL + dashboard de solo lectura	/srv-auditoria	D
Panel de control (`panel-control`)	Estado y arranque/parada de los stacks; activación de consolas	/	D

Servicio	Función	Ruta	Origen
Verifiers (`verifiers/_comun`)	Plantilla multi-instancia: endpoint oficial + UI oficial + haproxy; `levantar.sh <nombre>`	/verifier-<n>	C I
Portales (`verifiers/<n>`)	Aplicación de negocio de cada caso de uso (Node/Express)	/<n>	D S
Postman (`postman`)	Colecciones de integración (p. ej. notarías)	—	D

6. La wallet (New Wallet)

La wallet es la aplicación Android derivada de la referencia EUDI. Mantiene su arquitectura modular por capas: **features** en Jetpack Compose con patrón MVI, **lógica de negocio** inyectada con Koin y el **SDK Wallet Core** como motor de credenciales.



Reutilizado del repositorio de referencia EUDI (C), con módulos y parches propios (I/D) señalados en el texto.

Figura 3. Módulos de la wallet por capas (nombres de módulo del repositorio).

6.1 Lo que aporta este proyecto

- **Ecosistema parametrizado:** `publicar-wallet.sh` compila la variante `devDebug` con las URL del ecosistema (emisores, wallet provider, banco, auditoría) y la publica como descarga con huella SHA-256 y QR en el panel de auditoría.
- **Entrega automática del banco:** `BancoOfertas` consulta periódicamente al banco las cuentas nuevas del titular y las acepta; al cerrar una cuenta la credencial revocada se elimina sola (`deleteRevokedDocumentsOfType`).
- **Presentación fiel:** el nombre y el producto de la credencial bancaria («Cuenta Bancaria», tipo de cuenta), el icono del emisor y las fechas estrictas (un número de cuenta no se interpreta como fecha).
- **Apariencia:** ajustes con tema azul (por defecto), blanco o negro.

- **Reporte a la auditoría:** altas, ingresos, solicitudes y presentaciones con resultado y error; solo nombres de datos, nunca valores; si el centro no responde, la wallet sigue y reintenta.
- **Autenticar y firmar:** flujo RQES contra Andes SCD con la biblioteca de CSC.

6.2 Qué guarda y dónde

Credenciales y claves viven solo en el teléfono (almacén de Wallet Core sobre Android Keystore). El respaldo automático de Android está desactivado: los datos no salen del dispositivo, lo que protege las claves pero obliga a reemitir al cambiar de teléfono (sección 10).

7. Emisión de credenciales

La emisión usa **OpenID4VCI**. El emisor publica su metadata en `/.well-known/openid-credential-issuer/<prefijo>`; la wallet obtiene la oferta, se autoriza y presenta la prueba de posesión de su clave.

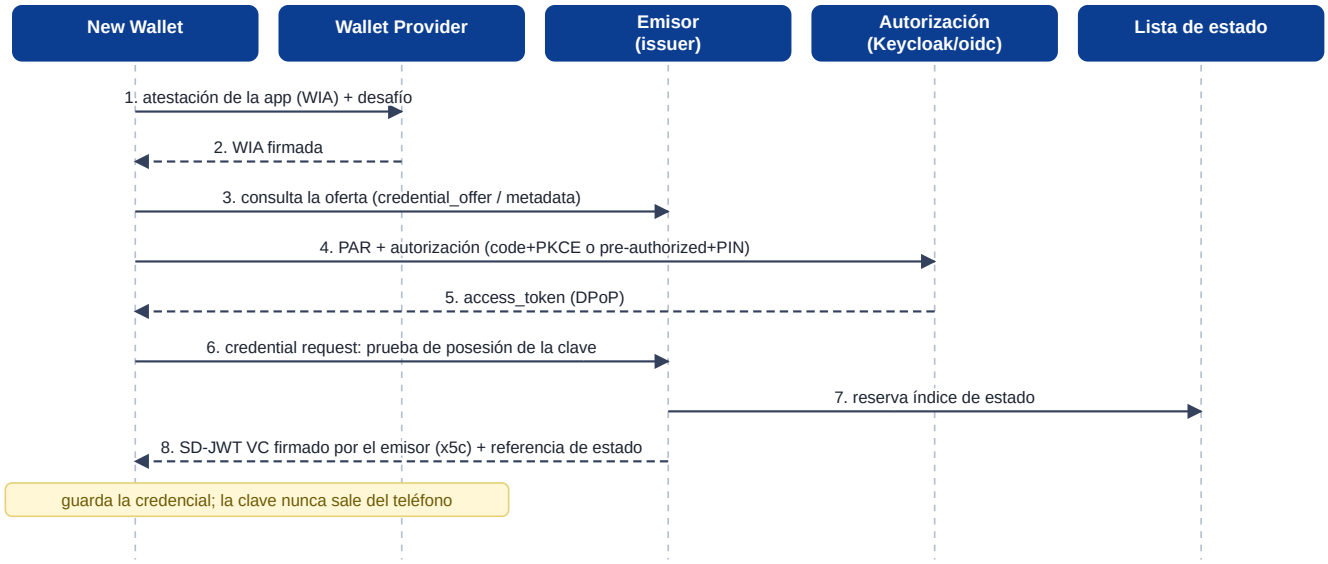


Figura 4. Secuencia de emisión con atestación de la wallet, token DPoP y lista de estado.

7.1 Dos modalidades de autorización

- **Código de autorización + PKCE** (Registraduría, Tránsito, UIS): la persona se autentica en el Keycloak del emisor; el PID se obtiene tras el onboarding.
- **Código pre-autorizado + PIN (`tx_code`)** (portales y banco): el portal crea la oferta para un titular ya identificado con su PID y la wallet la canjea con un PIN que se muestra aparte. El banco, además, encola ofertas por titular para que la wallet las recoja sin intervención.

7.2 Garantías incorporadas

- **Atestación de la app (WIA / ABCA):** el Wallet Provider comprueba que la solicitud viene de uno de los paquetes autorizados antes de que un emisor entregue nada.
- **DPoP** liga el token a la clave de la wallet; la prueba de posesión liga la credencial a esa misma clave.
- **Estado:** cada credencial reserva un índice en la lista de estado de su emisor (`status-list-*`).

- **Identidad como dependencia:** el PID es el anclaje; la mayoría de portales y la notaría exigen presentarlo antes de emitir. Los datos personales de la credencial salen del PID y llegan de solo lectura.

7.3 Emisores propios de los portales

Banco, EPS, gimnasio, aerolínea, cancillería y la notaría simple implementan el lado emisor dentro del propio portal (metadata, oferta, token, credencial, estado) con su propia PKI y su ancla en TL/PUBEAA. Soportan **reexpedición** (la copia anterior queda revocada y la nueva usa otro índice) en notaría, cancillería y aerolínea.

8. Presentación y verificadores

Cada portal delega la parte criptográfica en **su propio verifier** (`verifier-<nombre>`): el endpoint oficial de la referencia EUDI con su interfaz y un haproxy. El portal solo crea transacciones, lee resultados y aplica reglas de negocio.

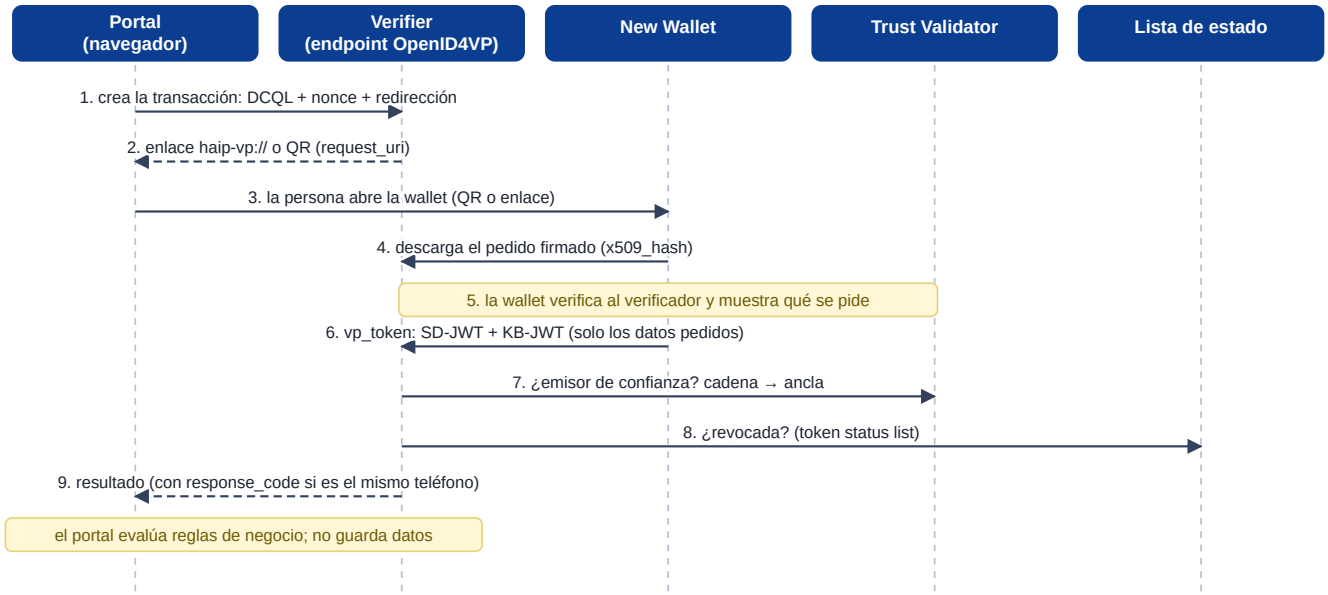


Figura 5. Secuencia de presentación (OpenID4VP) entre portal, verifier, wallet y capa de confianza.

8.1 Lo que garantiza el verifier antes de entregar datos

- Firma del emisor válida y cadena hasta un ancla de la lista de confianza.
- Estado de la credencial (no revocada ni suspendida).
- La presenta su titular: KB-JWT con el *nonce* de esa solicitud.
- Se piden solo los datos necesarios (DCQL con **filtros por valor**: la wallet ofrece solo las credenciales que los cumplen; p. ej. nivel académico y «graduado»).

8.2 Mismo dispositivo y otro dispositivo

Desde un computador el portal muestra un QR y consulta el resultado. En el propio teléfono muestra «Abrir mi wallet» (`haip-vp://`) y pide al verifier que la wallet vuelva a `/volver?response_code=…`; el resultado

solo se libera con ese código y a la sesión que creó la solicitud (cookie HttpOnly firmada). Así, un QR en la misma pantalla que la wallet no es un obstáculo.

8.3 Inicio de sesión con el PID

Los portales de pensiones y contratación se identifican con el PID (nombre y documento) y guardan esa identidad solo en la sesión en memoria; las demás consultas se comparan contra ella (por ejemplo, que el titular de la fe de vida sea quien inició sesión).

8.4 Catálogo de verificadores

Portal	Pide	Emite / produce	Regla de negocio
Banco	PID (ingreso y apertura)	Cuenta Bancaria (auto-entrega y baja al cerrar)	Cliente por cédula; producto por tipo
Beca	PID (solo «mayor de 18») + credencial académica	—	Combina dos emisores en una presentación
Contratación	Credencial académica por nivel (+ PID de sesión)	Contrato firmado (Andes SCD)	Solo «graduado»; filtros por nivel
Pensiones	PID (sesión) + fe de vida notarial	Certificado de pensionado y desprendible (en portal)	Fe de vida de notaría de confianza, vigente, mismo titular
EPS	PID	Carné de afiliado; resumen de historia clínica	Afiliación
Gimnasio	PID	Tarjeta de socio	Plan, aforo, control de ingreso y egreso
Aerolínea	PID (nombre, nacimiento, foto)	Tiquete	Adulto / niño / infante; embarque
Cancillería	PID (lugar de nacimiento, sexo, retrato)	Pasaporte (reexpedición)	Datos del PID, no del formulario
Migración	Pasaporte + PID	—	Cruce de retratos; entrada y salida
Notaría	PID	Fe de vida, poder, declaración, escritura…	Mayoría de edad; anulación y reexpedición
Acceso	PID con foto	—	El guardia compara foto y nombre
Discoteca	PID (solo edad)	—	`age_equal_or_over.18`
Firma (Andes)	PID (documento, nombre)	—	Identifica al firmante
UIS	Credencial académica / carné	—	Verificación de la propia universidad

9. Modelo de confianza

La confianza no se configura en cada verificador: se **publica** en listas firmadas y se **valida** con un servicio común.

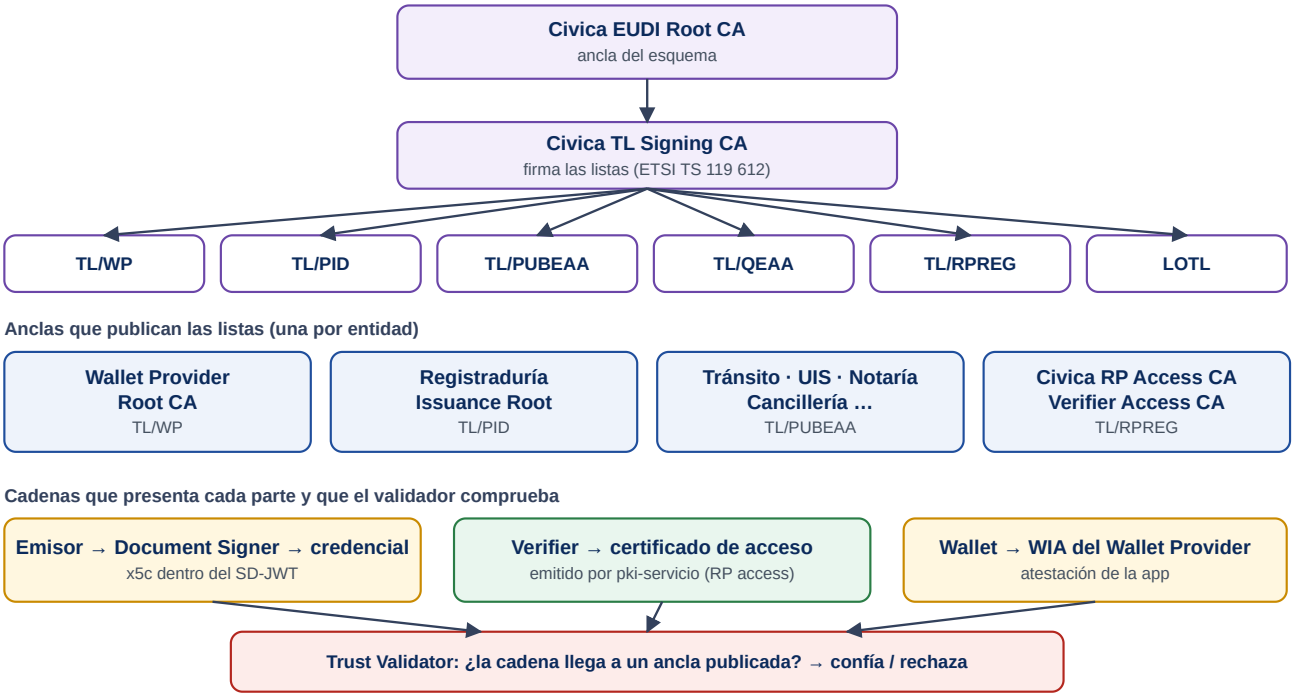


Figura 6. Jerarquía de confianza y cadenas que valida el Trust Validator.

9.1 Piezas

- **Listas (ETSI TS 119 612):** TL/WP, TL/PID, TL/PUBEAA, TL/QEAA, TL/RPREG y la LOTL, firmadas por *Civica TL Signing CA*. Cada publicación es inmutable y se sirve por número de secuencia; republicar crea la siguiente (hoy la 34 en PUBEAA).
- **Trust Validator:** usa un almacén de anclas construido con las **mismas** anclas que publica el publicador, por lo que validador y listas no pueden discrepar.
- **Certificados de acceso de verificadores:** el `pki-servicio` emite el certificado de cada verifier desde *Civica RP Access CA*; el `client_id` es `x509_hash` del certificado. La wallet lo comprueba contra TL/RPREG.
- **Estado:** `status-list-*` por emisor, con token status lists públicas.

9.2 Confianza por cadena, no por URL

> Un emisor es de confianza si la cadena de su credencial llega a un **ancla publicada**, sin importar el prefijo desde el que se sirva. Ejemplo observado: el emisor de la notaría de la pila EUDI (`/notaria-issuer`) firma con *Notaría Avance Root CA*, ancla ya publicada en TL/PUBEAA para la notaría simple (`/notaria`); por eso sus credenciales se validan sin registro adicional. La consecuencia práctica: **las reglas de negocio que comparan el «emisor» como URL deben aceptar ambos prefijos** (así se corrigió en pensiones y EPS).

9.3 Verificación de integridad

`verificar-cadenas.py` comprueba que la cadena que cada emisor presenta llega al ancla publicada, y detecta el fallo más peligroso: un ancla con el mismo CN pero distinto certificado. `probar-ecosistema.py` es la prueba de humo del validador.

10. Revocación y recuperación

10.1 Revocación

Cada credencial emitida lleva un índice en una **Token Status List**. Revocar es poner a 1 el bit; los verificadores consultan la lista pública y rechazan. El emisor guarda el **titular** (`subject`) de cada credencial para poder revocar por persona.

Mecanismo	Quién	Efecto
Botón del panel del emisor, `./revocar.sh` o API interna	Administrador del emisor	Revoca todas las credenciales de un titular, con motivo y bloqueo opcional
Trabajo periódico (8 h)	Emisor	Revoca credenciales cuya wallet o almacén de claves figura como inválido
Cierre en el portal (p. ej. banco)	Portal emisor	Revoca la credencial de la cuenta; la wallet la elimina sola
Bloqueo de emisión por titular	Emisor	Impide una nueva credencial al titular que reportó fraude

La revocación **no borra datos del titular** (se marca el registro con fecha y motivo) y las credenciales revocadas no se purgan al vencer. Cada revocación genera un aviso al titular con plazo de 24 h.

10.2 Reinstalar y cambiar de teléfono

Sin respaldo automático, un teléfono nuevo exige repetir el onboarding y reemitir. Notaría, cancillería y aerolínea reemiten y revocan la copia anterior. **Brecha conocida:** no hay un endpoint para revocar la wallet en el proveedor ni un medio de identificarse que no dependa de la wallet perdida; por eso una persona sin su teléfono no puede, por ejemplo, anular un trámite notarial por sí misma. Ver `docs/RECUPERACION-WALLET-ARF.md`.

11. Firma electrónica (Andes SCD)

El prestador de firma remota **simula** a Andes SCD para el banco de pruebas (no tiene respaldo de ONAC y toda pantalla lo dice). Implementa lo que usa la biblioteca de la wallet:

- **API CSC v2:** `info`, `credentials/list`, `credentials/info`, `signatures/signHash`, `signatures/timestamp`.
- **OAuth2:** código + PKCE, PAR (RFC 9126) y RAR con `authorization_details`.
- **Identificación con el PID** mediante `verifier-firma`: sin PIN, el firmante presenta su PID y se recuerda 10 minutos en esa sesión.

- **Certificados:** sub-CA QTSP del ecosistema, perfil `qtsp-user` (no repudio, 825 días). **Claves:** una por firmante, cifradas (Fernet); en producción serían un HSM.
- **Sello de tiempo** RFC 3161 con una TSA propia.

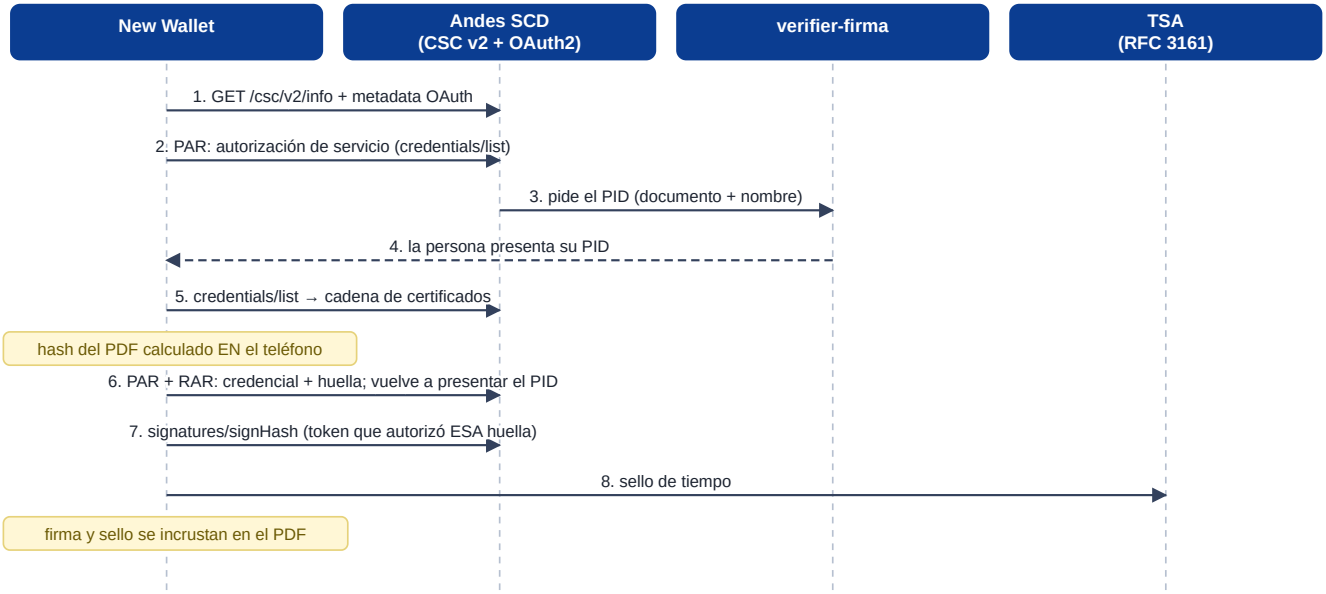


Figura 7. Flujo de firma de un documento desde la wallet.

El principio que ordena el diseño: **el documento nunca sale del teléfono** (solo su huella) y `signHash` firma únicamente con un token que autorizó **esa** huella; un token de simple inicio de sesión o una huella distinta responde 403. El portal de contratación usa este servicio para firmar el contrato de trabajo y verifica la firma y el sello al recibirlos; si la wallet firma sin sello, el portal lo añade y lo informa.

12. Auditoría y operación

12.1 Centro de auditoría

Es monitoreo: la wallet *reporta* y el centro registra, sin alterar emisores, listas ni flujos. Una API de ingesta (clave por wallet, idempotente por `evento_id`) alimenta un esquema PostgreSQL `auditoria` en español, de solo inserción (un *trigger* impide modificar o borrar). El dashboard es de solo lectura, corre en transacción `READ ONLY`, ofrece extracto con filtros y exportación CSV, y solo se abre desde IPs de administración.

```
usuario ──< medio_contacto
   └──< wallet ──1:1── dispositivo
          ├──< sesion            ingresos y salidas
          ├──< credencial        lo que tuvo la wallet
          └──< actividad >── contraparte (emisor | verificador)
                 └──< actividad_elemento   nombres de datos, nunca valores
```

Cada actividad guarda fecha, tipo, contraparte, **nombre de la credencial**, resultado, tipo y código de error y duración. El esquema y 13 tipos de actividad iniciales se exportan en `srv-auditoria/db/auditoria-inicial.sql`.

12.2 Operación

- `./up.sh`, `./estado.sh`, `./down.sh` levantan, consultan y bajan los stacks; el **panel de control** lo hace por botones y permite «Activar consola» de un Keycloak.
- `publicar-wallet.sh` compila y publica el APK; el panel de auditoría sirve siempre el último (huella SHA-256 y QR).
- Cada `up.sh` de proyecto es idempotente y no regenera la PKI existente: regenerarla invalidaría lo publicado en las listas.
- **Arranque completo (12-nov-2026):** la Notaría EUDI, Andes SCD, el verifier de firma y el gimnasio no estaban en `up.sh` y se cayeron tras un reinicio, dando 502 en el borde. Ya se incorporaron a `up.sh`, `levantar-portales.sh` y `estado.sh`; todos tienen `restart: unless-stopped`. Falta el chequeo de salud (sección 15).

13. Seguridad y privacidad

Principio	Cómo se logra	Dónde
Control del titular	Nada se comparte sin confirmación con PIN o huella; la wallet muestra quién pide qué y para qué	Wallet
Divulgación selectiva	SD-JWT VC: solo los datos pedidos viajan; filtros por valor y predicados (edad ≥ 18)	Wallet + verifier
Claves del titular	Generadas y usadas en el teléfono (Keystore); respaldo de Android desactivado	Wallet
Legitimidad de la app	Atestación WIA del Wallet Provider antes de emitir	Wallet Provider
Legitimidad del verificador	Certificado de acceso (x509_hash) emitido por una CA de TL/RPREG	Verifier + pki-servicio
Autenticidad del emisor	Cadena hasta un ancla publicada; estado por lista	Trust Validator
Sin seguimiento	Sin base central de identidades; el verificador no guarda datos; sesiones solo en memoria	Portales
Mínima exposición	Bases privadas, un solo borde, dashboards de datos personales restringidos por IP	nw-nginx
Trazabilidad	Extracto de solo inserción; nombres de datos, nunca valores	Auditoría
Firma	Huella calculada en el teléfono; token ligado a la huella autorizada; claves cifradas	Andes SCD

Los resultados de los portales no se escriben en los registros del servidor: el log solo dice «verificada/rechazada». Los datos personales de la sesión (nombre, documento) viven en la memoria del proceso y desaparecen al cerrar sesión o reiniciar.

14. Decisiones de arquitectura

#	Decisión	Motivo	Consecuencia
1	Un solo nginx de borde; los haproxy internos solo reescriben rutas	Un punto de TLS, de rutas y de control de acceso	Todo emisor/portal exige una regla en el `map`; el orden de reglas importa
2	Un solo Wallet Provider para los dos paquetes Android	Evitar PKI y estado duplicados	Los dos APK comparten atestación
3	Un solo Trust Validator y un almacén construido desde las anclas publicadas	Que validador y listas no puedan discrepar	Cambiar anclas exige reconstruir el almacén y reiniciar el validador
4	Un verifier por portal	Aislar certificados, propósitos y sesiones; que la wallet muestre «quién pide» con su propio nombre	Más contenedores (3 por portal), más certificados
5	Confianza por cadena, no por URL	Un emisor puede servirse por más de un prefijo	Las reglas de negocio no deben comparar el emisor como URL única
6	Prefijos de ruta, no subdominios	El certificado comodín no cubre segundo nivel	Cookies con nombre propio por portal
7	Emisión pre-autorizada con PIN en los portales; código+PKCE en emisores oficiales	El portal ya conoce al titular (PID); los emisores oficiales delegan en Keycloak	Dos variantes de flujo para mantener
8	El PID como anclaje de identidad de los portales	Una sola identidad de base verificable	Sin PID no se opera; la revocación del PID es crítica
9	Claves de firma en el prestador (cifradas); documento nunca sale del teléfono	Modelo de firma remota CSC	En producción requiere HSM
10	Auditoría como monitoreo pasivo y de solo inserción	No alterar flujos; trazabilidad	La wallet reintenta si el centro no responde
11	Sin DID ni VDR en el camino obligatorio	Alineación con EUDI/ARF	Extensión did:web queda fuera del alcance
12	Sesiones de portales en memoria	Simplicidad y no guardar datos personales	Se pierden al reiniciar un servicio

15. Estado, brechas y riesgos

15.1 Qué está operando

Emisión y presentación de punta a punta con la wallet instalada en un teléfono, listas publicadas (secuencia 34), cadenas validadas, revocación por titular, firma con Andes SCD y auditoría con el panel.

15.2 Brechas y riesgos

Tema	Hallazgo	Impacto	Acción propuesta
Arranque (corregido 12-nov)	Notaría EUDI, Andes SCD, verifier de firma y gimnasio faltaban en `up.sh` y `estado.sh` y cayeron tras un reinicio (502). Ya están en ambos y con `restart: unless-stopped`	Un fallo posterior no avisa: sin healthcheck	Healthcheck y estado en el panel
Dos notarías	`/notaria` y `/notaria-issuer` emiten el mismo tipo de fe de vida con distinto emisor	Reglas de negocio que comparan URL rechazan una de ellas (ocurrió en pensiones y EPS)	Aceptar ambos prefijos (hecho) o consolidar en una; registrar la URL del emisor nuevo en TL/PUBEAA
Prueba de vida	El onboarding compara rostros pero no detecta vida	Un PID podría obtenerse con una foto	Añadir liveness antes de cualquier uso real
Entidades simuladas	Registraduría, notarías, banco, EPS y Andes SCD son simulados	Sin validez legal ni reconocimiento	Declararlo en cada pantalla (ya se hace) y planear integraciones autorizadas
Sesiones en memoria	Los portales pierden sesión y resultados al reiniciarse	Experiencia, no seguridad	Aceptable en pruebas; persistir solo lo necesario si se requiere
Revocación de wallet	No hay endpoint de revocación de la wallet en el proveedor ni identificación sin la wallet	Pérdida de teléfono sin remedio inmediato	Ver propuesta en `RECUPERACION-WALLET-ARF.md`
PID anterior al 30-oct	Según REVOCACION.md (30-oct), 640 PID emitidos antes no tienen titular guardado ni punto de estado propio	Solo los alcanza el trabajo periódico	Reemitir o migrar
Certificación	Reutilizar repositorios de referencia no otorga certificación	No es una wallet certificada	Mantener el aviso; planear evaluación si se pasa a producción
Listas WRPAC/WRPRC	El ancla del verifier está en TL/RPREG; si la Comisión publica otro nombre habrá que duplicar	Compatibilidad futura	Seguir la publicación de ARF

16. Hoja de ruta

1. **Operación fiable:** chequeo de salud y alertas en el panel (el arranque y reinicio ya están resueltos).
2. **Consolidar notarías:** decidir un único emisor de fe de vida y su registro propio en la lista.
3. **Identidad robusta:** prueba de vida en el onboarding; recuperación y revocación de wallet; migración de PID anteriores.
4. **Confianza completa:** listas WRPAC/WRPRC, registro de partes usuarias y chequeo de registro en la wallet.
5. **Más ecosistema:** proximidad (mdoc por BLE/NFC) en los puntos de acceso y emisores autorizados reales cuando existan acuerdos.
6. **Firma:** HSM y política de certificados cuando se pase a un prestador acreditado.

Anexos

A. Rutas del borde (resumen)

Prefijo	Destino
/wallet-provider	spartans-wallet-provider
/onboarding · /biometrics	onboarding-backend · onboarding-biometrics
/pid-registraduria · /idp-reg	haproxy-reg
/pid-transito · /idp-tra	haproxy-tra
/uis-issuer · /idp-uis	haproxy-uis
/notaria-issuer	haproxy-notaria
/status-list/<emisor>	status-list-* (se quita el prefijo)
/tl-publisher · /TL · /LOTL · /tl-api · /trust/*	tl-publisher
/pki	tl-publisher-pki (AIA, CRL, CPS, OCSP)
/trust-validator · /validate	trust-validator
/andes-scd	andes-scd
/srv-auditoria	auditoria-api (dashboard solo desde IPs de administración)
/verifier-<n> y /<n>	verifier-<n> y portal <n>
(resto)	panel de control

B. Credenciales (`vct`) emitidas por el ecosistema

Emisor	Credencial	vct
Registraduría	PID	urn:eudi:pid:1 · eu.europa.ec.eudi.pid.1 (mdoc)
Tránsito	Licencia de conducción	mDL (ISO 18013-5)
UIS	Académica · Carné	urn:eudi:academic:credential:1
Notaría	Fe de vida, poder especial, declaración extraproceso, reconocimiento, autenticación de firma, copia de escritura, registro civil…	urn:co:notaria:*:1
Banco	Cuenta Bancaria	urn:co:banco:cuenta-bancaria:1
EPS	Carné de afiliado · Resumen de historia clínica	urn:co:eps:*:1
Gimnasio	Tarjeta de socio	urn:co:gym:tarjeta-socio:1
Aerolínea	Tiquete	urn:co:aerolinea:tiquete:1
Cancillería	Pasaporte	urn:co:cancilleria:pasaporte:1

C. Glosario

ARF: Architecture and Reference Framework de EUDI. **PID:** Person Identification Data (cédula digital). **SD-JWT VC:** credencial con divulgación selectiva. **DCQL:** lenguaje de consulta de credenciales de OpenID4VP. **WIA/ABCA:** atestación de la instancia de wallet. **DPoP:** prueba de posesión del token. **TL/LOTL:** lista de confianza / lista de listas. **CSC:** Cloud Signature Consortium. **RQES:** firma electrónica cualificada remota. **QTSP:** prestador cualificado de servicios de confianza. **RP:** parte usuaria (verificador).

D. Fuentes dentro del repositorio

- `ECOSISTEMA.md` — manifiesto de roles, rutas y decisiones.
- `docs/REVOCACION.md`, `docs/RECUPERACION-WALLET-ARF.md`, `docs/PLAN-AUTENTICAR-Y-FIRMAR.md`.
- `verifiers/docs/PLAN.md`, `srv-andes-scd/README.md`, `srv-auditoria/README.md`, `eudi-srv-issuer-pid-notaria/PLAN.md`.
- `srv-nw-nginx/nginx.conf`, `srv-tl-publisher/listas-publicadas`.